

Decal Brasil



Diagnóstico da estrutura para implementação do Programa de Governança e Compliance

Maio de 2017

Nosso entendimento



Valores e princípios éticos são fundamentais nas relações de negócios. São a base da estrutura de governança e *compliance* e protegem a imagem e reputação das organizações.

Nesse contexto, entendemos que a Decal Brasil busca apoio na avaliação da maturidade atual e riscos relacionados sobre suas iniciativas, processos, controles internos e estrutura de governança e *compliance*, bem como na proposição de recomendações de melhoria.

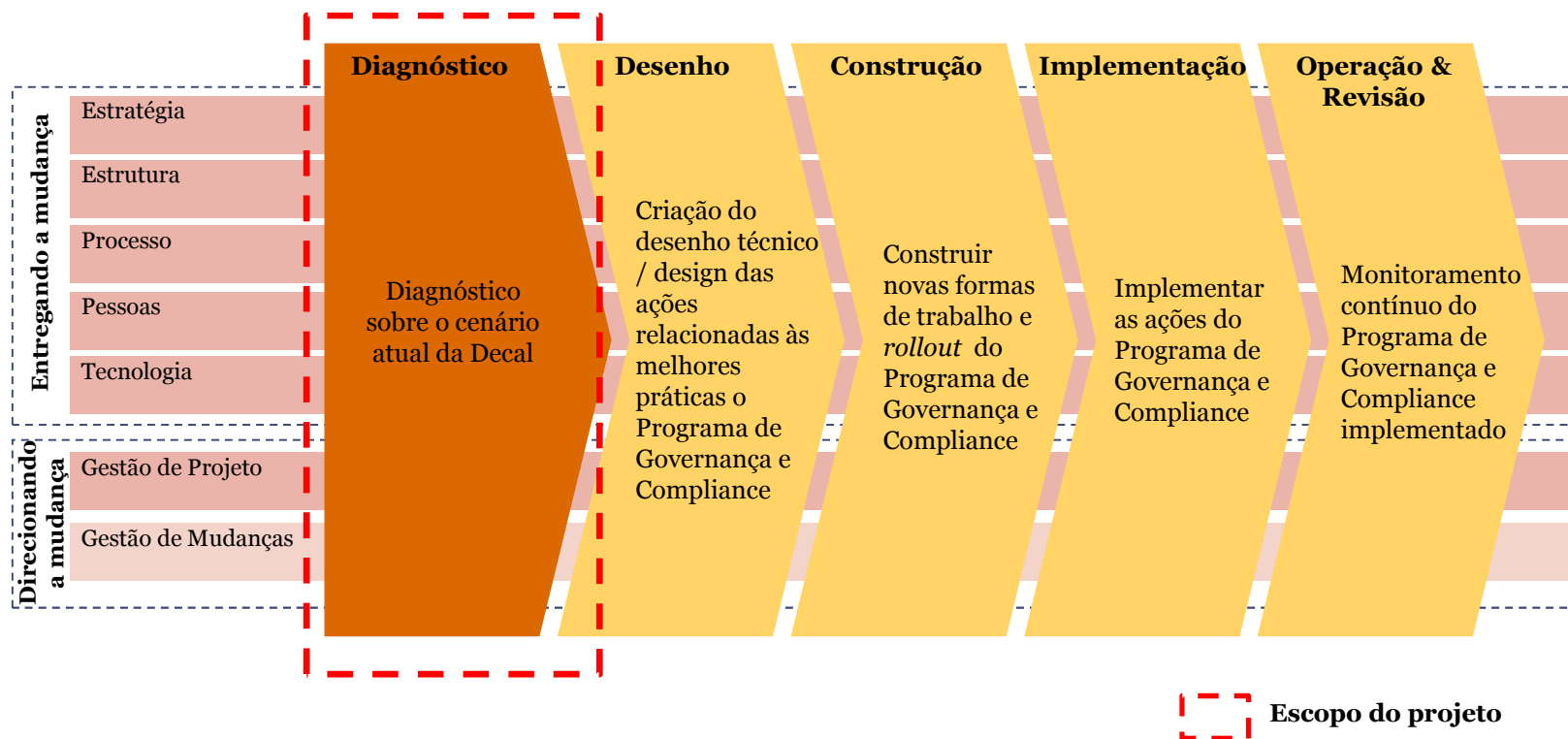
Com base nesta avaliação, a Decal poderá definir prioridades de projetos, ações e também a devida alocação de orçamento para aperfeiçoar o nível de maturidade sobre sua estrutura de governança e *compliance*.

Neste sentido, apresentamos proposta de prestação de serviços, tendo como base as melhores práticas e iniciativas de governança e controles relacionados à experiência da PwC e às diretrizes para empresas privadas (programa de integridade) da Controladoria Geral da União.

Minuta para discussão.

Escopo e abordagem

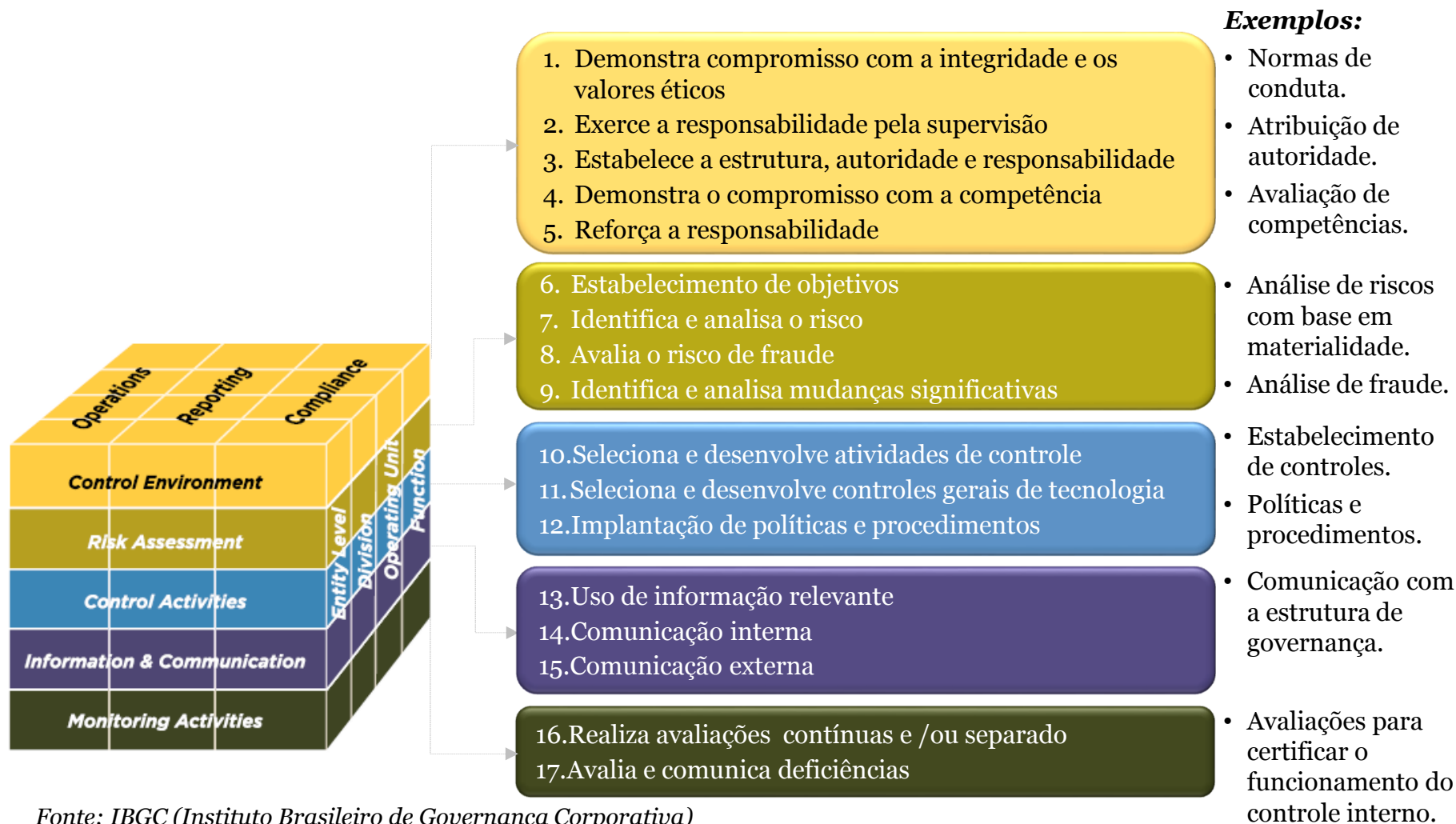
Com base na necessidade da Decal, estruturamos o projeto em 5 fases, sendo a fase de diagnóstico o escopo desta proposta, que visa a obtenção do entendimento do cenário atual. Após o diagnóstico, será possível estimarmos de forma mais precisa os esforços necessários, assim como o envolvimento da PwC, para as fases subsequentes. De acordo com a ilustração abaixo, as fases de Desenho, Construção e Implementação de ações direcionadas e complementares às já existentes se fazem necessárias para a estruturação de um Programa de Governança e Compliance robusto e efetivo e de acordo com a realidade da Decal Brasil.



Minuta para discussão.

Abordagem metodológica

Para realização do trabalho, utilizaremos frameworks com base nas melhores práticas e iniciativas de governança e controles relacionados ao framework COSO 2013 e ao guia de integridade pública da CGU (Controladoria Geral da União).



Fonte: IBGC (Instituto Brasileiro de Governança Corporativa)

Minuta para discussão.

Abordagem metodológica

Para realização do trabalho, utilizaremos frameworks com base nas melhores práticas e iniciativas de governança e controles relacionados ao guia de integridade pública da CGU (Controladoria Geral da União) e na experiência da PwC.

Programa de Integridade (Compliance) da CGU

- *tem como foco medidas anticorrupção adotadas pela empresa, especialmente aquelas que visem a prevenção, detecção e remediação dos atos lesivos contra a administração pública nacional e estrangeira previstos na Lei nº 12.846/2013.*

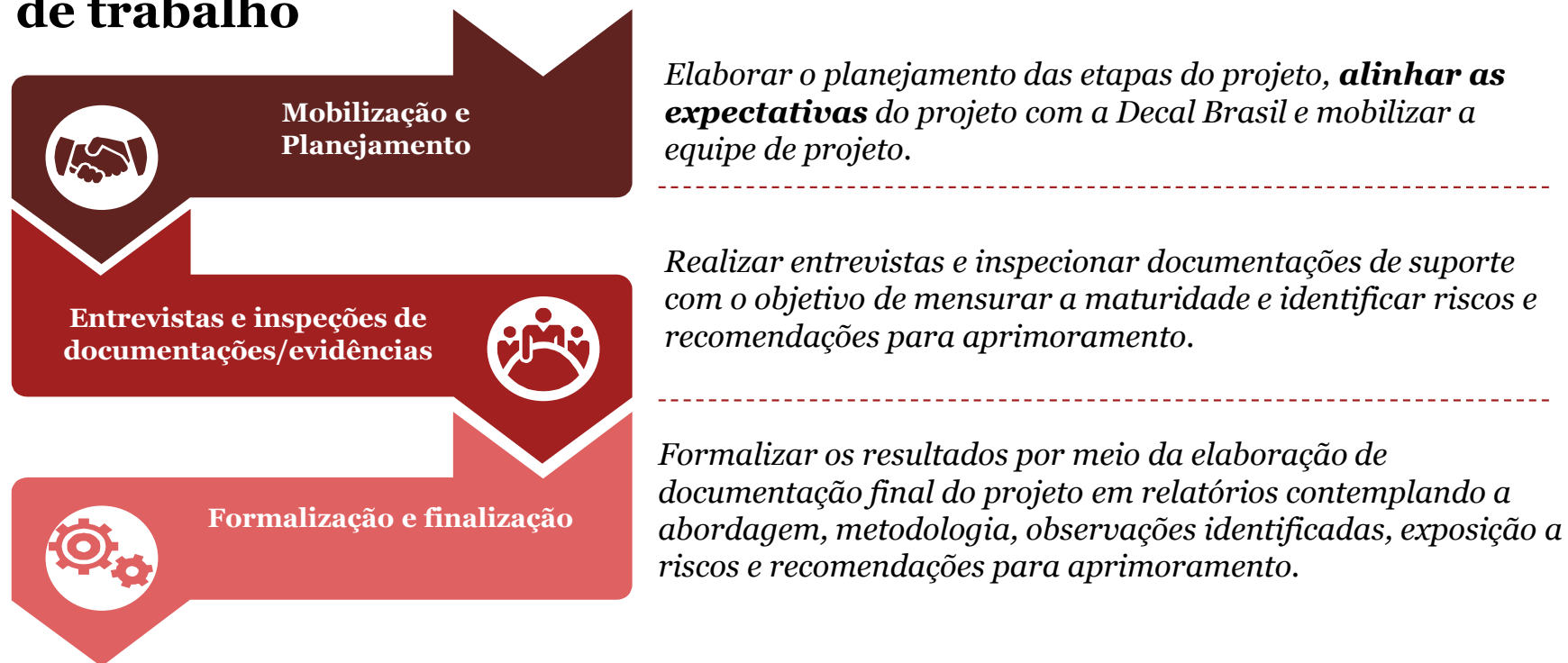


Fonte: CGU (Controladoria Geral da União)

Minuta para discussão.

Como conduziremos o nosso projeto

Principais etapas de trabalho



Detalhamento das etapas

Etapa	Atividades	Produtos
<i>Mobilização e Planejamento</i>	<i>1. Realizar reunião de kick-off com o objetivo de apresentar e reforçar a importância do projeto.</i> <i>2. Construir em conjunto com a Decal Brasil uma matriz de responsabilidades (RACI) do projeto.</i> <i>3. Identificar em conjunto com a Decal Brasil as pessoas-chave, responsáveis pela execução e supervisão dos processos de negócios e colaboradores expostos aos riscos de conformidade.</i> <i>4. Detalhar em conjunto com a Decal Brasil o cronograma com as atividades.</i>	<i>• Matriz de responsabilidades.</i> <i>• Cronograma</i>

Detalhamento das etapas

Etapa	Atividades	Produtos
Entrevistas e inspeções de documentações /evidências	1. Aplicar questionário junto a pessoas-chave (responsáveis pelos processos de negócios e colaboradores expostos ao risco de conformidade) para a avaliação da maturidade (estimadas 3 reuniões). 2. Analisar os documentos existentes, tais como políticas, procedimentos e normas internas. 3. Realizar entrevistas com os responsáveis pela governança da Decal (estimadas 3 reuniões). 4. Analisar a estrutura atual em relação a boas práticas de governança corporativa e para a gestão dos riscos de compliance.	• Matriz com o detalhamento das áreas contendo os itens avaliados e resultados obtidos de acordo com as melhores práticas.

Detalhamento das etapas

Etapa	Atividades	Produtos
<i>Formalização e finalização</i>	<i>1. Consolidar e formalizar os resultados obtidos.</i> <i>2. Discutir os resultados com a Decal Brasil.</i> <i>3. Apresentar os resultados do projeto.</i>	• Relatório contendo as atividades realizadas, resultados e recomendações. • Sumário e Apresentação Executiva

Cronograma

Estimamos o projeto em 6 semanas (*dependendo da disponibilidade dos executivos da Decal*).

Execução	S1	S2	S3	S4
Reuniões semanais de status		☆	☆	☆
Mobilização e Planejamento				
Realizar reunião de Kick-off				
Construir matriz de responsabilidade				
Identificar pessoas-chave				
Revisar cronograma				
Entrevistas e inspeções de documentos				
Aplicar questionário				
Analisar documentações				
Realizar entrevistas com responsáveis pela Governança*				
Analisar estrutura atual				
Formalização e finalização				
Consolidar e discutir resultados				
Finalização, elaboração do relatório final e apresentação dos resultados do projeto				

*Essa etapa depende da agenda dos executivos da Decal Brasil.

Minuta para discussão.

Entregáveis

www.pwc.com/br

pwc

Sumário Executivo

A PwC foi contratada para realizar testes de segurança nos ambientes tecnológicos do CLIENTE, simulando ações que um atacante interno poderia realizar contra a infraestrutura de TI, aplicações web, bem como no seu ambiente físico (servidores), a partir de riscos e vulnerabilidades existentes, sem a utilização de conhecimento prévio dos ambientes e dos controles de segurança implantados no ambiente. As atividades foram realizadas entre dezembro e janeiro de 2018.

Análise de Vulnerabilidades de Infraestrutura e Aplicações Web

O escopo do teste de intrusão foi constituído pelas ações de TI presentes nos escritórios do CLIENTE e também suas páginas Web acessíveis pela Internet. A execução dos testes permitiu nos identificar que a maior parte dos hosts avaliados possuem vulnerabilidades que tem um grau de criticidade média/baixa.

Segue abaixo a visão sumarizada dos resultados do projeto apresentada por disciplina de teste:

a. Footprinting, foram evidenciados 40 registros de domínio relacionados à CLIENTE e nenhuma vulnerabilidade crítica a partir do Footprinting;

b. Análise de segurança de Infraestrutura, o ambiente de infraestrutura externo não apresentou vulnerabilidades que possibilitassem a invasão do perímetro, porém o ambiente interno possui vulnerabilidades que nos permitiu acessar o módulo administrativo de sistemas críticos da empresa, bem como acesso administrativo ao banco de dados de sistemas críticos da CLIENTE e compartilhamento de arquivos de sistemas.

Também foi possível verificar parte dos resultados obtidos durante o projeto forma possível a partir de falhas humanas, sendo a falta de conscientização de segurança ao lidar com pessoas ou com a salvaguarda de e-mails e acesso. Segue abaixo, uma sumarização das vulnerabilidades encontradas para os ambientes de infraestrutura e aplicações web:

Vulnerabilidades de Aplicação

Nível	Porcentagem
Baixa	69%
Média	25%
Alta	6%

Vulnerabilidades de Infraestrutura

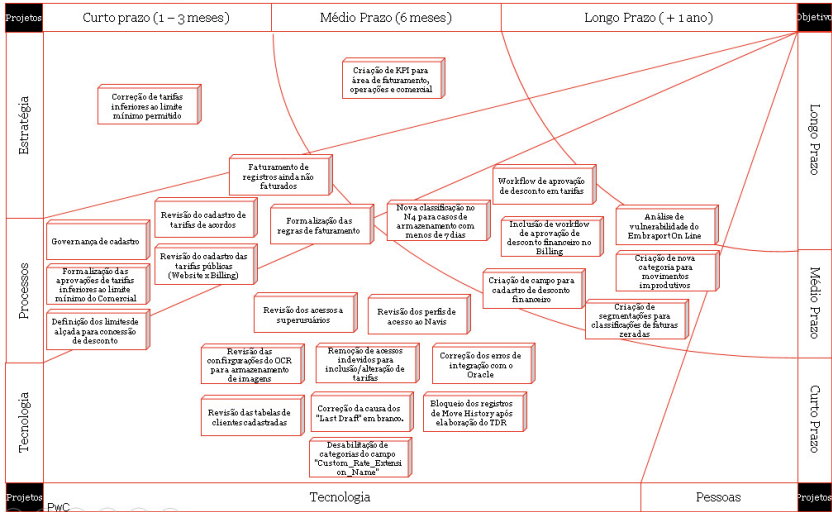
Nível	Porcentagem
Baixa	55%
Média	23%
Alta	22%
Crítica	2%

Gráfico 1 - Total de vulnerabilidades aplicações web e infraestrutura

Por meio dos testes foi possível constatar que melhorias são necessárias nos ambientes que suportam a CLIENTE para assegurar a confidencialidade, integridade e disponibilidade dos dados que são tratados, processados e armazenados no ambiente online.

Sumário Executivo

Roadmap das recomendações ao modelo atual



Roadmap de recomendações

RECUPERAR (RC)	Planejamento de Recuperação (RC.RP): Processos e procedimentos de recuperação são executados e mantidos para garantir uma restauração oportuna de sistemas ou ativos afetados por eventos de segurança cibernética.	RC.RP-1: O Plano de recuperação é executado durante ou depois de um incidente	- CCS CSC 8 - COBIT 5 DSS02.05, DSS03.04 - ISO/IEC 27001:2013 A.16.1.5 - NIST SP 800-63 Rev. 4 CP-10, IR-4, IR-8
	Melhoramentos (RC.IM): Planejamento e processos de recuperação são melhorados ao incorporar lições aprendidas em atividades futuras.	RC.IM-1: Recovery plans incorporate lessons learned.	- COBIT 5 BAIO5.07 - ISA 62443-2-1 4.4.3.4 - NIST SP 800-63 Rev. 4 CP-2, IR-4, IR-8
	Comunicações (RC.CO): Atividades de restauração são coordenadas com partes internas e externas, como centros de coordenação, provedores de serviço de internet, donos de sistemas atacantes, vítimas, outros CSIRT e fornecedores.	RC.CO-1: As relações públicas estão sendo gerenciadas.	- COBIT 5 BAIO7.08 - NIST SP 800-63 Rev. 4 CP-2, IR-4, IR-8
		RC.CO-2: A reputação após um evento está reparada.	- COBIT 5 EDM03.02 - COBIT 5 MEA03.02
		RC.CO-3: Atividades de recuperação estão sendo comunicadas para stakeholders internos e equipes executivas e de gerenciamento.	- NIST SP 800-63 Rev. 4 CP-2, IR-4

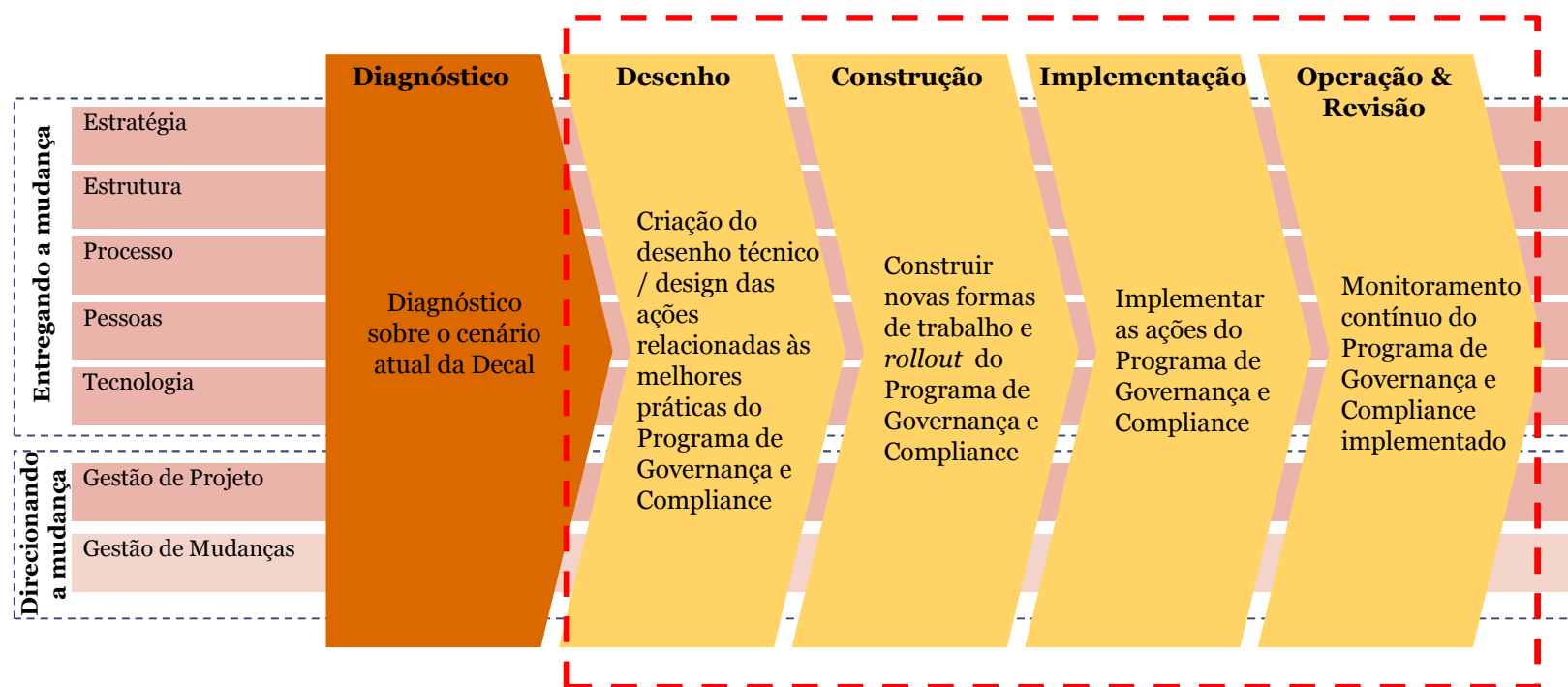
Matriz de recomendações

Com base no diagnóstico, a Decal Brasil poderá definir prioridades de projetos, ações e também a devida alocação de orçamento para aperfeiçoar o nível de maturidade de Compliance.

Minuta para discussão.

Fases subsequentes ao diagnóstico

Com base no resultado do diagnóstico, será possível avançar para as fases de Desenho, Construção, Implementação e Operação e Revisão (monitoramento). Desta forma, será possível estimarmos de forma mais precisa os esforços necessários para as fases subsequentes.



Possível escopo futuro

Minuta para discussão.

Investimento

Considerando os serviços descritos neste documento e a estimativa de tempo para a sua execução, os honorários são de:

Honorários líquidos	R\$ 28.700,00
----------------------------	----------------------

O valor dos honorários, na forma prevista anteriormente, não inclui o valor referente aos impostos ISS, PIS e COFINS incidentes sobre os serviços ora contratados, com pagamento de 70% deste valor, quando da contratação dos serviços. O saldo remanescente será devido para pagamento quando da entrega da minuta dos produtos.

As despesas com transporte e outros gastos serão discutidas e cobradas periodicamente, ao custo.

Comentários finais

Este material tem a finalidade de apresentar nossa firma e fornecer aspectos prévios e sumários dos serviços que nos propomos a realizar. O conteúdo deste documento não implica, para qualquer uma das partes, obrigação de aceitação, contratação ou qualquer outra forma de vinculação. A formalização contratual, caso haja interesse das partes, ocorrerá por meio de “carta de contratação de prestação de serviços”, que será encaminhada após definição detalhada do escopo e consequente apuração efetiva dos honorários.

Minuta para discussão.

© 2017 PricewaterhouseCoopers Contadores Públicos Ltda. Todos os direitos reservados. Neste documento, “PwC” refere-se à PricewaterhouseCoopers Contadores Públicos Ltda, a qual é uma firma membro do network da PricewaterhouseCoopers, sendo que cada firma membro constitui-se em uma pessoa jurídica totalmente separada e independente.

O termo “PwC” refere-se à rede (network) de firmas membro da PricewaterhouseCoopers International Limited (PwCIL) ou, conforme o contexto determina, a cada uma das firmas membro participantes da rede da PwC. Cada firma membro da rede constitui uma pessoa jurídica separada e independente e que não atua como agente da PwCIL nem de qualquer outra firma membro. A PwCIL não presta serviços a clientes. A PwCIL não é responsável ou se obriga pelos atos ou omissões de qualquer de suas firmas membro, tampouco controla o julgamento profissional das referidas firmas ou pode obrigá-las de qualquer forma. Nenhuma firma membro é responsável pelos atos ou omissões de outra firma membro, nem controla o julgamento profissional de outra firma membro ou da PwCIL, nem pode obrigá-las de qualquer forma.

